



MERIDIAN TRUST BANK THREAT HUNTING & DETECTION ENGINEERING

Extending Incident Response to Fleet-Wide Hunting and Detection

Carter Yanosick

Cybersecurity for Professionals Bootcamp

Week 6, Days 4–5 — Hands-On Lab

Case MTB-IR-2026-0902

September 2026

Executive Summary

This phase extended a confirmed single-host compromise (the internet-facing customer portal, MTB-WEB01) into a fleet-wide threat hunt. Perimeter firewall telemetry pushed the true start of the intrusion five days earlier than the original disk-based timeline showed, and a hypothesis-driven hunt across the remaining four hosts identified a second compromised server that the initial forensic investigation never touched.

The raw indicator list from the original investigation was rewritten using the Pyramid of Pain, the intrusion was mapped end to end against MITRE ATT&CK, and four Sigma detection rules were written against attacker behavior rather than specific addresses or hashes — a distinction the hunt itself proved necessary, since the attacker used different infrastructure and a different persistence mechanism on the second host.

The attacker did not reuse their tooling on the second host: a different C2 address, a different beacon filename, and a different persistence mechanism (systemd instead of cron). An indicator-only hunt built from the first host's IOCs would have missed the second compromise entirely — which is the case for detecting behavior instead of addresses.

1. Scope and Method

This phase covered the same five-host environment as the original assessment, extended with 90 days of perimeter firewall egress records and cross-host authentication and process telemetry. The goal was to answer two questions the original forensic report could not: how long had this actually been going on, and is the attacker anywhere else.

1.1 Environment Assessed

Host	Address	Role	Status at Start of Hunt
MTB-WEB01	10.50.2.24	DMZ customer portal	Confirmed compromised (Day 3)
MTB-APP01	10.50.2.25	Application and file transfer	Unknown
MTB-FILE01	10.50.2.26	Internal file server	Unknown
MTB-DC01	10.50.2.10	Windows domain controller	Unknown
MTB-DVWA01	10.50.2.30	Test web application	Unknown

1.2 Tools and Methodology

Tool	Purpose
CyberChef	Extracting IOCs from egress and telemetry logs, counting occurrences, defanging indicators
MITRE ATT&CK	Mapping every step of the intrusion to a stable technique identifier
Sigma	Writing vendor-neutral detection rules for the behaviors identified

Tool	Purpose
Spreadsheet	Egress log analysis, fleet hunt grid, tiered indicator list, ATT&CK map

2. Extending the Investigation

2.1 Revised Timeline

The Day 3 timeline started on 2 September because that is where the disk evidence started — the imaged host's access log only retained records back to 1 September, and the file-system timeline can only show files that still existed at acquisition. Neither reaches far enough back to show when the attacker actually arrived. Ninety days of perimeter firewall egress records do.

Time (UTC)	Event	Evidence Source	Confidence
2026-08-28 01:52	First contact from attacker; automated scanning begins	Egress log	Confirmed
2026-08-30 02:09	First outbound connection from WEB01 to attacker C2 — host already compromised	Egress log	Confirmed
2026-09-02 02:38	2.9 MB transfer, WEB01 → 185.220.101.47	Egress log	Confirmed
2026-09-02 02:52	FILE01 accepts SSH publickey login for svc-backup from WEB01	Auth log	Confirmed
2026-09-02 05:12	9.9 MB transfer, FILE01 → 185.220.102.244	Egress log	Confirmed

Revised start of intrusion: 2026-08-28 — five days earlier than the Day 3 disk-based timeline. The disk image couldn't show this because of log rotation, and because none of the early reconnaissance activity ever wrote a file for a file-system timeline to catch.

2.2 Fleet Hunt Results

A hunt grid was built across all five hosts against the indicators recovered so far, then re-run against each new indicator discovered along the way.

Host	Attacker C2 #1	Attacker C2 #2	Backdoor Account	Verdict
MTB-WEB01	Yes	No	Yes	Compromised
MTB-APP01	No	No	No	Clean
MTB-FILE01	No	Yes	Yes	Compromised
MTB-DC01	No	No	No	Clean
MTB-DVWA01	No	No	No	Clean

2.3 Second Compromised Host: MTB-FILE01

FILE01's authentication log shows an accepted SSH publickey login for svc-backup, originating from WEB01, shortly after root was obtained there. The attacker authenticated with the stolen SSH private key, not a password — root access on WEB01 is what let them read and exfiltrate it. Once on FILE01 they repeated the same play: a matching UID-0 backdoor account and a second beacon, but with none of the original host's tooling reused.

	MTB-WEB01	MTB-FILE01
C2 destination	185.220.101.47	185.220.102.244
Beacon file path	/usr/local/bin/apache-worker	/usr/local/sbin/syslog-forward
Persistence mechanism	cron.d entry	systemd unit

2.4 Ruling Out a False Positive: MTB-DVWA01

MTB-DVWA01 shows the same beacon-like characteristic that got WEB01 flagged in the first place: a persistent outbound session on a regular five-minute interval.

Periodicity is not proof of a beacon — plenty of legitimate software checks in on a fixed schedule. What separates a compromise from a monitoring agent is whether the process, destination, and schedule are all accounted for by something documented. MTB-DVWA01's asset register confirms the session belongs to an approved monitoring agent with an uptime that predates the intrusion. An analyst who can't make that distinction either misses real beacons or floods the team with false alarms until people stop reading the alerts.

3. Indicator Analysis and ATT&CK Mapping

The hunt demonstrated that an indicator list built from the first compromised host would have missed the second one entirely. The Pyramid of Pain (Bianco, 2013) explains why, and reframes which indicators are worth building lasting detections around.

3.1 Pyramid of Pain

Tier	Indicator Type	Attacker Cost to Change	Example
6 (top)	TTPs	Would abandon the technique	Beacon launched by a persistence mechanism, fixed interval
5	Tools	Reuse a different implant	The specific beacon binary
4	Host / network artifacts	Rename a file or directory	Root-owned process in /usr/local/
2	IP addresses	Seconds	185.220.101.47, 185.220.102.244
1 (bottom)	Hash values	Seconds	SHA-256 of style.php, apache-worker

The C2 address from the first host was blocked after the initial investigation and achieved almost nothing — the attacker was already using an unrelated second address on the other host, at zero cost to them. What didn't change between the two hosts was the shape of the behavior: a root-owned binary outside

package-manager control, launched by a persistence mechanism, holding a long-lived outbound session at a fixed interval. Detecting that costs the attacker their whole technique, not a rename.

3.2 MITRE ATT&CK Mapping

Tactic	Technique	Evidence
Reconnaissance	T1595.002 — Vulnerability Scanning	Egress log, 28 Aug — 214 zero-byte sessions to port 80
Initial Access	T1190 — Exploit Public-Facing Application	WEB01 access.log — path traversal (CVE-2021-42013)
Persistence	T1505.003 — Web Shell	WEB01 — style.php dropped in /uploads/
Privilege Escalation	T1068 — Exploitation for Privilege Escalation	WEB01 auth.log — pkexec session (PwnKit)
Persistence	T1136.001 — Local Account	WEB01 auth.log — useradd, svc-backup
Persistence	T1098.004 — SSH Authorized Keys	WEB01 — authorized_keys entry created
Persistence	T1053.003 — Cron	WEB01 — cron.d/apache-logrotate
Persistence	T1543.002 — Systemd Service	FILE01 auth.log
Credential Access	T1552.004 — Unsecured Credentials: Private Keys	Key placed in svc-backup's authorized_keys
Lateral Movement	T1021.004 — Remote Services: SSH	FILE01 auth.log — accepted publickey from WEB01
Collection	T1560.001 — Archive via Utility	WEB01 — recovered .bash_history, tar czf
Command and Control	T1071.001 — Web Protocols	WEB01 — apache-worker to 185.220.101.47:8443
Exfiltration	T1041 — Exfiltration Over C2 Channel	Egress log — 2.9 MB to 185.220.101.47:8443
Defense Evasion	T1070.003 — Clear Command History	WEB01 file timeline
Defense Evasion	T1027 — Obfuscated Files or Information	Base64 string in style.php, decoded in CyberChef

Tactics used: Reconnaissance, Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Command and Control, Exfiltration. Tactics not used: Resource Development, Impact, Defense Impairment.

4. Detection Engineering

The original report's recommendation was "better monitoring." The fleet hunt showed why the obvious version of that fails: block one address or hash one file, and the attacker used different infrastructure on the second host at zero cost. These four rules are written against behavior instead, so they still fire if the attacker changes infrastructure.

4.1 Detection Rule Summary

Rule	Detects	ATT&CK Tag	Level	Pyramid Tier
mtb_detect_01	Cron/systemd persistence launching a binary from /usr/local	t1053.003, t1543.002	High	4
mtb_detect_02	Script file dropped into a web-served upload directory	t1505.003	Critical	6
mtb_detect_03	Encoded directory traversal against a CGI path	t1190	Medium	6
mtb_detect_04	SSH login for a service account from the server segment	t1021.004, t1078.003	High	6

4.2 Representative Rule

```

title: Persistence Binary Launched From /usr/local by Cron or Systemd
status: experimental
description: |
  Detects a scheduled or service-managed process executing a binary
  from /usr/local/, outside package-manager control. This is the
  mechanism that relaunched the beacon on both compromised hosts.
logsource:
  category: process_creation
  product: linux
detection:
  selection:
    ParentImage|contains: ['cron', 'systemd']
    Image|startswith: '/usr/local/'
  condition: selection
falsepositives:
  - An approved ops automation binary deployed to /usr/local/ as part
    of a documented change. Should match a change record.
level: high

```

4.3 Evasion Resistance

Rule	What It Would Take to Evade
mtb_detect_01	Stop using /usr/local and stop relying on cron/systemd for persistence entirely — not just rename the binary
mtb_detect_02	Find an initial-access path that never writes a server-side script at all — not just a different filename

Rule	What It Would Take to Evade
mtb_detect_03	Use a different exploitation technique entirely — not just a different target path
mtb_detect_04	Route lateral movement through an actual workstation instead of a server-segment host

5. Containment, Eradication & Recovery

5.1 Containment

Host	Action	Rationale
WEB01	Isolate at network layer via firewall block	Stops the beacon and further data loss without destroying volatile evidence
WEB01	Lock (not delete) the svc-backup account	Blocks re-entry while preserving the account for investigation
FILE01	Live-capture processes, connections, sessions before touching anything	Preserves volatile state ahead of the disk image
Both	Do not power off	Consistent with order-of-volatility — powering off loses running-state evidence

5.2 Eradication

Access Path	Host(s)	Removal / Verification
CVE-2021-42013 path traversal	WEB01	Upgrade Apache to 2.4.51; rescan to confirm
Backdoor account svc-backup (UID 0)	WEB01, FILE01	Delete account on both; verify removal
Beacon binaries and persistence entries	WEB01, FILE01	Delete files, remove cron/systemd entries, reload
Reused SSH private key	WEB01, FILE01	Revoke/rotate fleet-wide; strip public key from all authorized_keys

5.3 Recovery

- FILE01 returns to service first (internal-only, lower risk); WEB01 returns last, once fully patched.
- Safe backup generation: anything predating 2026-08-28 01:52 UTC, verified against the known-clean file list and the four detection rules before trust.
- WEB01 re-exposure requires Apache and PwnKit both patched, the filesystem-root misconfiguration fixed, and the eradication table fully verified.
- 60-day heightened monitoring: new accounts, new SSH keys, new cron/systemd jobs, unusual outbound traffic — all four detection rules running continuously.

6. Post-Incident Review

6.1 Detection Gap

Moment	Timestamp (UTC)	Time After First Activity
First attacker activity	2026-08-28 01:52:17	—
First successful exploitation	2026-08-30 02:09:12	2 days, 0h 17m
Second host compromised	2026-09-02 02:52:14	5 days, 1h 0m
Largest data transfer	2026-09-02 05:12:19	5 days, 3h 20m
Alert reached a human	2026-09-02 09:47:12	5 days, 7h 55m

mtb_detect_03 is the only one of the four rules that would have fired before any actual damage occurred — acting on it would have prevented nearly the entire intrusion. None of the four rules would have caught the initial reconnaissance phase; every detection set has gaps, and a review that claims otherwise isn't credible.

6.2 Root Cause and Contributing Factors

Question	Finding
Why was a known, actively exploited vulnerability still exposed?	The process has no mechanism turning a high finding into a forced deadline. Assessment and remediation need to be connected by more than a report.
Why did the scan run after the first successful exploitation?	The internet-facing host was scanned on the same generic cadence as every other host. Scan cadence needs to track risk, not be uniform.
Why was an unattended SSH key trusted by other hosts?	The DMZ-to-server-segment trust model is flat instead of segmented. A DMZ host should never hold a credential that grants access inward.
Why did 7.5 hours of beaconing go unalerted?	The data was in the log the entire time. What was missing was real-time alerting on the first anomalous connection, not a rule that needs a pattern to accumulate.

7. Key Takeaways

A single evidence source should never be trusted for "when did this start." Disk evidence has a limited memory — log rotation and file timelines only show what survives to the moment you look. Cross-checking against a longer-retention source (90 days of firewall logs) surfaced five additional days of dwell time the original investigation could not have found.

Attackers reusing access rarely reuse tooling. A different address, filename, and persistence mechanism on the second host meant an indicator-only hunt would have missed it entirely — the fix is hunting for behavior, not the specific IOCs from the last host. Blocking an address or hashing a file barely inconveniences an attacker who can generate a new one in seconds; a behavioral detection costs them the whole technique, which is why Pyramid-of-Pain tier should drive what gets built into detection rules rather than what gets added to a block list. And ultimately, the data existed in the logs for the full 7.5-hour dwell window before detection — the failure wasn't visibility, it was that nobody was alerting on it in real time.

Skills Demonstrated

Hypothesis-driven threat hunting across a multi-host fleet; perimeter telemetry analysis to establish true intrusion timelines; false-positive/true-positive differentiation for beacon-like behavior using asset context; Pyramid of Pain indicator analysis; MITRE ATT&CK technique mapping; Sigma detection rule authoring against behavioral patterns; containment/eradication/recovery planning with credential blast-radius analysis; post-incident review and root-cause/process-failure analysis.